



MUCHANGI PATRICK & ASSOCIATES

ADVOCATES OF THE HIGH COURT OF KENYA · DIGITAL TRUST ASSURANCE

— REGULATORY ANALYSIS SERIES — NO. 005

Breach Response Readiness: The Hours That *Define Board Governance*

What separates an institution that manages a data breach from one a data breach manages.

PREPARED FOR

Boards & Executive
Leadership

SECTORS

Financial Services · Healthcare ·
Technology

PUBLICATION

Knowledge Centre,
2026

CONTENTS

In This Analysis

Exec.	Executive Summary	<u>3</u>
01	The Hours That Define Governance Maturity	<u>3</u>
02	What the Law Requires, and What Good Practice Requires Beyond It	<u>4</u>
03	Why Most Incident Plans Fail in the First Six Hours	<u>5</u>
04	The Board's Role Before, During and After a Breach	<u>5</u>
05	Building a Governance-Grade Breach Playbook	<u>6</u>
06	What Boards Should Ask Management	<u>6</u>
—	Rehearsed Hours, Not Improvised Ones	<u>7</u>

This analysis forms part of the Muchangi Patrick & Associates Advocates Knowledge Centre — the firm's Regulatory Analysis Series for Boards and executive leadership in Kenya.

Breach Response Readiness: The Hours That Define Board Governance

What separates an institution that manages a data breach from one a data breach manages.

EXECUTIVE SUMMARY

No institution can guarantee it will never suffer a data breach. What every institution can control is what happens in the hours immediately afterward — and it is that response, more than the incident itself, that regulators, clients and courts will ultimately judge.

Kenya's data protection framework expects controllers to notify the Office of the Data Protection Commissioner and affected data subjects without undue delay once a breach is identified — a standard increasingly benchmarked, in practice and in comparable frameworks such as the GDPR, against a 72-hour window. Few institutions have genuinely rehearsed what those hours would look like.

This analysis sets out why the earliest hours of a breach are where governance is tested most severely, and what a Board should have in place long before it needs it.

01

The Hours That Define Governance Maturity

The technical part of a breach — the vulnerability, the intrusion, the exfiltration — is usually over by the time anyone senior finds out about it.

What happens next is a governance test: how quickly the organisation understands what occurred, decides what it owes to whom, and communicates before the narrative is written for it by someone else.

What the Law Requires, and What Good Practice Requires Beyond It

Kenya's data protection regulations require notification of a breach to the regulator and affected individuals without undue delay. Many organisations, in our experience, treat "without undue delay" as licence to deliberate for days.

The safer institutional posture — and the one increasingly expected in practice — treats notification within roughly 72 hours as the working standard, the same benchmark used under the GDPR, rather than the outer limit of what is acceptable.

Why Most Incident Plans Fail in the First Six Hours

Plans fail early, not late. The most common failure is not a lack of technical capability but a lack of clarity about authority: who is allowed to say a breach has occurred, who can authorise notifying the regulator, and who speaks to the press — questions that should never be decided for the first time during an actual incident.

COMMON EARLY FAILURES

- No single incident lead named in advance
- Legal counsel contacted only after internal debate
- No pre-approved communication template

WHAT GOOD PRACTICE LOOKS LIKE

- A named lead with pre-delegated authority
- Counsel retained and briefed before an incident
- A holding statement drafted and approved in advance

The Board's Role Before, During and After a Breach

Before an incident, the Board's role is to ensure a credible plan exists and has been tested. During an incident, the Board's role is oversight and rapid decision-making, not day-to-day management of the response. After an incident, the Board's role is to ensure the organisation learns from it — genuinely, not only in the language of a post-incident report nobody revisits.

Building a Governance-Grade Breach Playbook

- A named incident lead with clearly delegated authority to act within hours, not days
- Legal counsel retained and briefed before an incident occurs
- A pre-approved communication template for regulators, customers and media
- A rehearsed tabletop exercise conducted at least annually
- A Board notification threshold that does not wait for certainty before triggering escalation

What Boards Should Ask Management

Every Board should be able to put the following questions to management, and expect a considered answer:

01	Do we have a named incident lead with pre-delegated authority to act immediately?
02	Is legal counsel retained and briefed before an incident, not found during one?
03	When did we last rehearse our breach response, and what did the rehearsal reveal?
04	What is our internal threshold for notifying the Board, and has it ever been tested?
05	Do we have a pre-approved communication template ready to adapt, not draft from scratch?
06	How would we demonstrate, after the fact, that we notified without undue delay?

CONCLUSION

Rehearsed Hours, Not Improvised Ones

A breach tests an institution's governance more honestly than almost any other event, because it happens on a timeline the institution does not control. The Boards that come through it with their credibility intact are, almost without exception, the ones that rehearsed the hours before they ever needed them.

BOARD CONSIDERATION

“If notified of a serious breach at 6 p.m. on a Friday, does your organisation know exactly what happens next?”

If the honest answer is uncertain, a rehearsed breach playbook — tested before it is needed — is the most consequential gap to close.

M

About the Author

Muchangi Patrick & Associates Advocates is a Kenyan law firm specialising in Digital Trust Assurance, data protection, technology law, AI governance and regulatory advisory. We help Boards understand, govern and continuously improve how their organisations manage information, technology, artificial intelligence and legal risk.

Request an Executive Briefing

We help leadership teams understand, govern and continuously improve Digital Trust through structured, evidence-based advisory engagements.

Pinetree Plaza, Nairobi · 0722 878 607 · consult@dataprivacyadvocates.co.ke